DIGITAL BANKING ARCHITECTURE & SECURITY ENGINEERING

Comprehensive Authentication & Lifecycle Specification

Document ID: ARCH-SPEC-AUTH-2026
Status: Approved Production Reference

1 Executive Architectural Scope

This formal specification defines the technical contracts, journey states, verification controls, and database transitions across the three core user lifecycle operations:

Module 1: New Registration

Zero-profile customer onboarding via BVN/NIN identity lookup, dual contact verification, biometric liveness, and credential creation.

Module 2: Existing Activation

Digital enrollment for established core banking accounts via Account + BVN binding, liveness verification, and profile synthesis.

Module 3: Login & Recovery

Multi-identifier access (Phone/Email/Account), trusted hardware binding with OTP challenges, and biometric forgot-passcode recovery.

2 Flow 1: New Customer Registration & KYC Verification

Enables prospective customers without existing banking records to open a Tier-1 digital account. Identity data is pulled from authoritative identity registries (NIBSS BVN or NIMC NIN) followed by mandatory multi-channel verification.

Step	Action & Payload Summary	Security / Governance Rule
1. Primary Identity	User supplies BVN (11 digits) or NIN (11 digits) plus optional referral code.	Strict rate limit (3 queries / IP / hr). Input sanitization against injection.
2. Registry Query	Backend contacts NIBSS / NIMC proxy service to resolve verified KYC profile.	Retrieves First Name, Last Name, Gender, DOB, Address, Phone, and Email.
3. Dual Path Contact Verification	• **Default Path (Use ID Info):** Verification SMS & Email dispatched to KYC registry contacts. • **Update Path:** User modifies contact. Dual OTPs dispatched to validate the new Phone & Email.	Customer cannot bypass contact ownership validation even when adopting default registry records. 300s OTP TTL.
4. Liveness Biometric	Frontend launches 3D passive/active liveness capture SDK. Stream evaluated server-side.	Must verify face matches government registry photo & threshold meets anti-spoofing standard.
5. Passcode & Account	Customer defines 6-digit numeric login passcode. Core Banking creates NUBAN CIF.	Passcode hashed via Argon2id. Welcome SMS/Email dispatched with new Account Number.

Flow 1 Key Endpoints

POST /API/V1/ONBOARDING/IDENTITY/VERIFY

```
{ "idType": "BVN", // or "NIN" "idNumber": "22222222222", "referralCode": "REF-9021" // optional } // Returns 200 with masked KYC data & sessionToken
```

POST /API/V1/ONBOARDING/CONTACT/VERIFY-OTP

```
{ "sessionToken": "sess-uuid-4412", "phoneOtp": "491823", "emailOtp": "782910" } // Returns 200 with livenessToken & SDK config
```

3 Flow 2: Existing Customer Digital Channel Activation

Existing account holders who maintain physical branch accounts or cards but lack digital credentials use this flow to bind their core CIF to the digital banking platform.

> **Core Invariant: Zero-Trust Identity Association**
> Account Number + BVN matching does **NOT** grant login authentication. It only establishes that the supplied parameters match a real record on the Core Banking System (CBS). Channel access requires non-repudiable biometric liveness verification to eliminate fraud via stolen BVNs.

Lifecycle Phase	Operation & Logic	Transition State
Phase 1: Input & Validation	Customer enters 10-digit NUBAN and 11-digit BVN. Backend verifies CBS CIF correlation, PND/lien status, and ensures no duplicate active profile exists.	`NOT_ACTIVATED` → `CUSTOMER_VERIFIED`
Phase 2: Liveness Session	Temporary session created. Biometric SDK captures 3D depth, blink, and facial landmarks; verifies genuine user presence against CBS master KYC photo.	`LIVENESS_PENDING` → `LIVENESS_VERIFIED`
Phase 3: Digital Profile	Customer verifies primary notification email and phone preferences; optional username assignment is executed.	`LIVENESS_VERIFIED` → `PROFILE_PENDING`
Phase 4: Passcode Creation	User creates 6-digit numeric login passcode. System validates non-sequential digits, hashes credential, and revokes activation token.	`PASSCODE_PENDING` → `ACTIVATED`
Phase 5: First-Time Login	Customer proceeds to regular login. System identifies device as untrusted and issues device registration OTP challenge before granting dashboard entry.	`ACTIVATED` → `DEVICE_BOUND`

Flow 2 Architectural Endpoints

POST /API/V1/AUTH/EXISTING-CUSTOMER/VERIFY

```
{ "accountNumber": "0123456789", "bvn": "22222222222" } // 200 OK: Returns sanitized verificationId // Omits: Name, balance, address, plain BVN
```

POST /API/V1/AUTH/EXISTING-CUSTOMER/LIVENESS/COMPLETE

```
{ "verificationId": "v-uuid-9842", "livenessSessionId": "live-session-8142" } // 200 OK: Returns short-lived activationToken // Token expires in 10 minutes
```

POST /API/V1/AUTH/EXISTING-CUSTOMER/PROFILE

```
{ "activationToken": "act-tk-882194", "email": "customer@domain.com", "phone": "08012345678" } // 200 OK: Profile record merged with CIF
```

POST /API/V1/AUTH/EXISTING-CUSTOMER/PASSCODE

```
{ "activationToken": "act-tk-882194", "passcode": "729104" } // 200 OK: Marks digitalProfile.status = "ACTIVE" // Revokes token permanently
```

4 Flow 3: Multi-Identifier Login & Device Trust Registration

The authentication system accepts three distinct primary identifiers paired with the customer's 6-digit login passcode. Every login payload submits device telemetry for trust validation.

Identifier: Phone Number
Formatted as local standard (`080...`) or E.164 international notation (`+234...`).

Identifier: Email Address
Valid RFC 5322 formatted address linked during onboarding or activation.

Identifier: Account Number
10-digit standard NUBAN account issued by the core banking engine.

Device Trust Evaluation & OTP Challenge Cycle

Upon credential verification, the backend queries the `trusted_devices` registry. If the submitted `deviceId` and fingerprint are not trusted, token generation is suspended and a **Device Registration OTP Challenge** is enforced.

POST /API/V1/AUTH/LOGIN

```
// Request Payload { "identifier": "080123
45678", // or email / NUBAN "passcode": "729104",
"deviceInfo": { "deviceId": "dev-ios-a78b456-fgh12
3", "deviceName": "iPhone 15 Pro", "platform": "IO
S", "fingerprint": "a9f8e4321..." } } // 403 Respo
nse: Device Challenge Required { "success": false,
"code": "DEVICE_REGISTRATION_REQUIRED", "message":
"Unrecognized device. OTP dispatched.", "data": {
"deviceEnrollmentId": "dev-enroll-4912", "maskedEm
ail": "c******r@domain.com", "maskedPhone": "080**
****78", "otpExpirySeconds": 300 } }
```

POST /API/V1/AUTH/DEVICE/VERIFY-OTP

```
// Verification Request { "deviceEnrollmen
tId": "dev-enroll-4912", "otp": "859204", "trustDe
vice": true } // 200 OK Response: Device Bound & T
okens Released { "success": true, "message": "Devi
ce authenticated successfully.", "data": { "access
Token": "eyJhbGciOiJIUzI1NiIsIn...", "refreshToke
n": "dGhpcy1pcy1hLXJlZnJlc2...", "expiresIn": 900,
"user": { "fullName": "Amina Abubakar", "requiresT
ransactionPin": true } } }
```

> **Simultaneous Dual-Channel OTP Broadcast**
> For device binding, the OTP is transmitted simultaneously via SMS gateway and high-priority SMTP mailer. The notification explicitly includes the device model, geolocation estimate, and a direct link/number to lock the account instantly if the request was unauthorized.

5 Dashboard Security & Transaction PIN Isolation

The **Login Passcode** (application entry) is architecturally isolated from the **Transaction PIN** (financial authorization). Upon initial entry to the dashboard, if `requiresTransactionPin == true`, transfers and bill payments remain disabled until a 4-digit PIN is configured via `POST /api/v1/customers/security/transaction-pin`.

6 Flow 3 (Continued): Forgot Passcode Recovery Flow

To prevent unauthorized credential hijackings via SIM swaps, call forwarding exploits, or email account compromises, the **Forgot Passcode** journey requires biometric liveness confirmation in addition to dual-channel OTP verification.

Recovery Phase	Operation & Payload Description	Fraud Prevention Safeguard
1. Initiation	User submits Account Number or Phone Number along with BVN via `/passcode/recovery/init`.	Validates account exists. Limits initiation to 3 requests per 24 hours per account.
2. Contact Challenge	6-digit recovery OTP dispatched to registered phone number and email address.	OTP valid for 300 seconds; maximum 3 verification attempts before session invalidation.
3. Biometric Liveness	Camera session launched. Biometric stream matched against core master KYC photograph.	Neutralizes SIM-swap fraud; proves the account holder is physically present.
4. Passcode Reset	User inputs New Passcode and Confirm Passcode using the verified `resetToken`.	New passcode cannot match the last 3 historical passcodes. Hashed via Argon2id.
5. Session Revocation	Passcode updated in database; system immediately evicts all existing access/refresh tokens.	Forces all active instances and registered hardware to re-authenticate.

Forgot Passcode API Sequence

POST /API/V1/AUTH/PASSCODE/RECOVERY/INIT

```
{ "identifier": "0123456789", // or Phone "bvn": "22222222222" } // Returns recoverySessionId & masked contacts
```

POST /API/V1/AUTH/PASSCODE/RECOVERY/LIVENESS

```
{ "recoverySessionId": "rec-session-1144", "livenessSessionId": "live-token-5521" } // Returns resetToken (TTL: 5 mins)
```

POST /API/V1/AUTH/PASSCODE/RECOVERY/VERIFY-OTP

```
{ "recoverySessionId": "rec-session-1144", "otp": "729104" } // Returns nextStep: "LIVENESS_CHECK"
```

POST /API/V1/AUTH/PASSCODE/RECOVERY/RESET

```
{ "resetToken": "rst-token-998811", "newPasscode": "918273", "confirmPasscode": "918273" } // 200 OK: Invalidate all sessions. Redirect to Login.
```

7 Enterprise Security Matrix

Credential Encryption Standards

- **Login Passcode:** Argon2id (m=65536, t=3, p=4) with per-user salt.
- **Transaction PIN:** Encrypted under ISO 9564 Format 0 within HSM.
- **Tokens:** Asymmetric RS256 JWTs with 15-minute expiration windows.

Audit & Telemetry Mandates

- Zero plain-text BVN, NIN, OTP, PIN, or Passcode in server logs.
- Audit records include UTC timestamp, IP, device UID, and channel ID.
- Immediate account lockout after 5 consecutive failed login attempts.